Poufność i kontrola dostępu do informacji

Materiał edukacyjny do demonstracji. Ogólne zagadnienia bezpieczeństwa informacji.

Zakres materiału

Uogólnione opracowanie edukacyjne. Nie jest tekstem normy ISO/IEC 27001 ani polityką konkretnej organizacji. Nie opisuje rzeczywistych kont, systemów, ról ani obiegów akceptacji.

Zakres ochrony

Należy rozpoznać informacje podlegające ochronie, ich właściciela i ograniczenia wykorzystania. Klasyfikacja powinna uwzględniać skutki utraty poufności, integralności lub dostępności.

Wiedza konieczna

Dostęp należy ograniczać do informacji potrzebnych do wykonania zadania. Uprawnienia powinny być adekwatne do aktualnych obowiązków i odbierane, gdy przestają być potrzebne.

Przekazywanie informacji

Przed przekazaniem informacji należy sprawdzić uprawnienia odbiorcy i dozwolony cel użycia. Kanał przekazania i zabezpieczenia powinny odpowiadać wrażliwości danych.

Treść zobowiązania do poufności

Umowa powinna określać informacje chronione, dozwolone wykorzystanie, zakres odbiorców, czas obowiązywania oraz obowiązki zapobiegania ujawnieniu. Należy uwzględnić własność informacji i prawa własności intelektualnej.

Naruszenie i zakończenie umowy

Należy ustalić powiadamianie o nieuprawnionym ujawnieniu, działania po naruszeniu, zwrot lub zniszczenie informacji i dalsze obowiązywanie poufności po zakończeniu współpracy.

Przegląd dostępu

Uprawnienia należy okresowo weryfikować oraz aktualizować po zmianie obowiązków lub zakończeniu współpracy. Zakres i częstotliwość przeglądu zależą od ryzyka.